



OWASP TOP 10 (2025 RELEASE)

Application Security Assessment

Ten risk categories, one verdict each, every verdict backed by a probe against the live system or a committed change. Issued for the Petroline Transport Ltd security review.

4

PASS

6

PARTIAL

0

FAIL

10

CATEGORIES

Product FleetOpsX / Karigo Command Center

Scope Production web platform — React/Vite SPA (Vercel),
Node/Express + Prisma API (2.28.45.216), PostgreSQL

Standard OWASP Top 10 (2025 Release)

Client Petroline Transport Ltd

Assessed 28 September 2026

Method Codebuff security pass — automated probes + source
review

Executive summary

The platform passes 4 of the ten OWASP Top 10 (2025) categories outright; 6 are partial with the gaps named and owned. Since the previous review the API gained server-side login rate limiting (6/min per IP+username, live-verified 401×6 → 429), a committed dependency lockfile closing an unpinned supply chain, and confirmed HTTPS with valid certificates at both public edges.

The residual risk is concentrated in host hardening (SSH, firewall, service user), the unencrypted Vercel→origin leg, session-token hygiene (30-day JWT in localStorage, no MFA), and observability (no log retention or alerting). Each is listed under its category with a concrete next step.

Reading note — **PASS**: control verified against the live system. **PARTIAL**: control present, named gap remains. **FAIL**: control absent.

A01 Broken Access Control

PASS

Server-side authorization is enforced on every sensitive route, multi-role aware, and probe-verified: partner tokens cannot read internal ledgers (403), forged tokens are rejected (401), and role changes to audit/login reports, expenses and tenant writes now gate on Transport Manager / Admin / HR / Accounts / FleetOps as appropriate.

EVIDENCE

- Partner JWT on internal routes → 403 on all probes; forged token → 401.
- Audit + login reports restricted to TM/Admin/HR; expenses POST/PATCH → TM/Admin/Accounts/FleetOps/HR; tenants GET → TM/Admin/HR, writes → TM/Admin (server hardening patch, verified by restart + probes).
- Frontend guards are cosmetic only; every decision is re-made server-side from the signed JWT.

REMAINING GAP

None known on the API surface. The tenancy model is single-tenant (tenant_001 default) — acceptable today, revisit if partner tenancy multiplies.

A02 Security Misconfiguration

PARTIAL

Helmet is on, CORS is a reflect-allowlist (unauthorized origins receive no CORS headers), 5 MB bodies are rejected with 413, and the API boots only with a strong JWT secret. Remaining exposure is at the host, not the app.

EVIDENCE

- Evil-origin probe (Origin: https://evil.example) → HTTP 200 with NO access-control-allow-origin header — browsers refuse the response.
- 5 MB payload probe → 413. JWT guard refuses boot without JWT_SECRET (64-hex, .env mode 600) unless ALLOW_INSECURE_JWT_FALLBACK=1.
- Both edges send HSTS: frontend max-age=63072000 includeSubDomains; preload, API max-age=31536000 includeSubDomains; API adds X-Frame-Options: SAMEORIGIN.

REMAINING GAP

SSH on the box allows root password login, UFW and fail2ban are off, the service runs as root, and ~60 probe/backup files sit in the web root. Host hardening (Appendix B of the security test report) remains open.

A03

Software Supply Chain Failures

PARTIAL

Dependency resolution is now pinned: package-lock.json was missing from the frontend, so every Vercel build re-resolved versions anew. With the lockfile committed, installs are reproducible and auditable, and `npm audit` reports exactly two known advisories.

EVIDENCE

- package-lock.json committed (8,014 lines) this release; npm audit now deterministic.
- npm audit: 2 HIGH — sheetJS Prototype Pollution (GHSA-4r6h-8v6p-xvw6) and ReDoS (GHSA-5pgg-2g8v-p4x9); no fixed version published by the vendor yet.

REMAINING GAP

Replace or patch `xlsx` when a fixed release lands (the vendor recommends the commercial distribution); add Dependabot/renovate so advisories surface automatically.

A04

Cryptographic Failures

PASS

Passwords are bcrypt-hashed, tokens are HMAC-SHA256 JWTs signed with a 64-hex secret held outside the repo, and all client→edge traffic is TLS 1.2+ under Let's Encrypt certificates valid to Nov 27 2026.

EVIDENCE

- bcrypt password hashes in the users table; no plaintext or reversible storage.
- openssl s_client: api.fleetopsx.com serves CN=*.fleetopsx.com (Let's Encrypt YR1, 2026-08-29 → 2026-11-27); fleetopsx.com serves CN=fleetopsx.com (YR2, same window).
- JWT secret rotation enforced at boot (refuses weak/absent secret).

REMAINING GAP

The Vercel → origin hop (vercel.json rewrite to http://2.28.45.216) is unencrypted on the public internet leg between Vercel's egress and the box. Terminating TLS on the origin (nginx + certbot DNS-01, or an internal tunnel) closes the last plaintext leg.

A05

Injection

PASS

All persistence flows through Prisma's parameterized client. The only raw SQL in the codebase is two \$queryRawUnsafe calls using \$-parameter binding, verified by review. User-typed strings are HTML-escaped before any print/interpolation sink.

EVIDENCE

- grep: 2 occurrences of \$queryRawUnsafe, both parameterized (lines ~1219/1230 of the API source); every other query is a typed Prisma call.
- escHtml + DOMParser allowlist sanitizer (printSheet) — added in the hardening pass after an XSS demonstration in map popups was fixed.

REMAINING GAP

None identified.

A06

Insecure Design

PARTIAL

The money model is deliberately honest — indirect figures are read from the departments that generate them and never re-entered; the analytics board states its gaps (trip revenue not yet recorded) instead of inventing numbers. Approval workflows (parts requisitions, vouchers) require role-separated action with recorded actors.

EVIDENCE

- Accounts boards read store movements, workshop work orders and the expense ledger as their sources of truth (tm-accounts.tsx design notes + live figures reconcile: Indirect ₦6,589,380 = Spare Parts ₦6,540,000 + Other ₦49,380).
- Parts approval desk: workshop raises → TM approves/rejects with mandatory note → store releases; decisions are attributed and listed.

REMAINING GAP

Login throttling existed only as recommendation until this release (now implemented, see A07); password policy is still minimum 6 characters — raise to 10+ with breach-list checks; JWT lifetime is 30 days in localStorage — move refresh tokens to httpOnly cookies.

A07

Authentication Failures

PARTIAL

Session tokens are signed and verified on every request, and THIS release added the missing control: a hand-rolled login rate limiter (6 attempts per minute per IP+username on all credential routes, 429 + Retry-After, success clears the counter). Live probe: six wrong-password attempts return 401, the seventh returns 429; a legitimate login immediately after returns 200.

EVIDENCE

- Probe on the live box: 401 401 401 401 401 401 429 (7th attempt), then TM login → 200.
- Covers /api/auth/login, register, partner login/register, forgot/reset-password and /api/users/me/password.
- JWT rotation log (login-reports) restricted to TM/Admin/HR; logout invalidates client-side.

REMAINING GAP

No server-side session revocation list (a stolen token is valid until 30-day expiry) and no MFA. Rate limiting now bounds online guessing; token hygiene is the next control.

A08

Software or Data Integrity Failures

PARTIAL

Deployment is GitHub → Vercel auto-deploy on push to main, with the lockfile now pinning the dependency graph; API changes ship as backed-up, idempotent patch scripts that are committed to the repo and re-runnable.

EVIDENCE

- package-lock.json committed (A03); every server patch (security hardening, login rate limiter) is a committed, idempotent script with a timestamped .bak and auto-revert on failed boot (the rate-limit patch self-reverted once on a bad probe port before succeeding).
- Codebuff provenance trailers on every commit; git history is the integrity log.

REMAINING GAP

No signed commits and no CI gate running tsc/tests before deploy; branch protection on main is not verified. Add a CI workflow that typechecks and audits on PR.

A09

Security Logging and Alerting Failures

PARTIAL

The API writes a login-reports trail (rotation events, per-login metadata) and a Notification model that files actions under the module and the roles that must act; Morgan logs HTTP traffic. There is no aggregation, retention policy or alerting.

EVIDENCE

- Login reports endpoint (TM/Admin/HR only) exposes per-account login history used by this assessment.
- pm2 file logs exist but rotate only by size; nothing watches them.

REMAINING GAP

No centralized log retention, no alert on brute-force patterns (the rate limiter's 429s are currently only visible in logs), no uptime monitoring. Ship pm2 logs + 429 counters to a log service and alert on spikes.

A10

Mishandling of Exceptional Conditions

PASS

Error paths answer with typed JSON messages, not stack traces: auth failures return structured 401/403 bodies, oversized payloads a clean 413, and the client renders departmental empty/failure states rather than crashing. The express default error handler does not leak stack traces in its JSON response.

EVIDENCE

- Probes: forged token → { error: 'Invalid token' } (401); partner on internal route → { error: 'Forbidden...' } (403); 5 MB body → 413 without stack.
- Client: Promise.allSettled data loads render 'could not reach the ledgers' states instead of white-screening; print pipeline sanitizes malformed HTML input.

REMAINING GAP

The API does not yet set NODE_ENV=production, so Express error pages could include stack traces if a handler ever calls next(err) with an Error — set it in .env (one line) to pin the behavior.